OWASP ZAP Scan Report

Target: https://u77w41.github.io/anurup/

All scanned sites: https://u77w41.github.io

Javascript included from: https://ssl.gstatic.com https://cdn.jsdelivr.net https://mail.google.com https://cdnjs.cloudflare.com https://fonts.gstatic.com https://fonts.googleapis.com https://u77w41.github.io

Generated on Tue, 27 Oct 2026 06:12:51

ZAP Version: 2.17.0

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	5
Low	2
Informational	3

Alerts

Name	Risk Level	Number of Instances
Absence of Anti-CSRF Tokens	Medium	3
Content Security Policy (CSP) Header Not Set	Medium	5
Cross-Domain Misconfiguration	Medium	5
Missing Anti-clickjacking Header	Medium	5
Sub Resource Integrity Attribute Missing	Medium	5
Strict-Transport-Security Header Not Set	Low	1
X-Content-Type-Options Header Missing	Low	5
Information Disclosure - Information in Browser localStorage	Informational	3
Re-examine Cache-control Directives	Informational	5
Retrieved from Cache	Informational	7

Passing Rules

Name	Rule Type	Threshold	Strength
Session Management Response Identified	Passive	MEDIUM	-
Verification Request Identified	Passive	MEDIUM	-
Private IP Disclosure	Passive	MEDIUM	-
Session ID in URL Rewrite	Passive	MEDIUM	-

Script Served From Malicious Domain (polyfill)	Passive	MEDIUM	-
ZAP is Out of Date	Passive	MEDIUM	-
Insecure JSF ViewState	Passive	MEDIUM	-
Vulnerable JS Library (Powered by Retire.js)	Passive	MEDIUM	-
Java Serialization Object	Passive	MEDIUM	-
In Page Banner Information Leak	Passive	MEDIUM	-
Charset Mismatch	Passive	MEDIUM	-
Cookie No HttpOnly Flag	Passive	MEDIUM	-
Cookie Without Secure Flag	Passive	MEDIUM	-
Cross-Domain JavaScript Source File Inclusion	Passive	MEDIUM	-
Content-Type Header Missing	Passive	MEDIUM	-
Application Error Disclosure	Passive	MEDIUM	-
Information Disclosure - Debug Error Messages	Passive	MEDIUM	-
Information Disclosure - Sensitive Information in URL	Passive	MEDIUM	-
Information Disclosure - Sensitive Information in HTTP Referrer Header	Passive	MEDIUM	-
Information Disclosure - Suspicious Comments	Passive	MEDIUM	-
Off-site Redirect	Passive	MEDIUM	-
Cookie Poisoning	Passive	MEDIUM	-
User Controllable Charset	Passive	MEDIUM	-
User Controllable HTML Element Attribute (Potential XSS)	Passive	MEDIUM	-
WSDL File Detection	Passive	MEDIUM	-
Loosely Scoped Cookie	Passive	MEDIUM	-
Viewstate	Passive	MEDIUM	-
Directory Browsing	Passive	MEDIUM	-
Heartbleed OpenSSL Vulnerability (Indicative)	Passive	MEDIUM	-
HTTP Server Response Header	Passive	MEDIUM	-
Server Side Technology Version with Known Vulnerabilities	Passive	MEDIUM	-
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	Passive	MEDIUM	-
X-Backend-Server Header Information Leak	Passive	MEDIUM	-
Secure Pages Include Mixed Content	Passive	MEDIUM	-
HTTP to HTTPS Insecure Transition in Form Post	Passive	MEDIUM	-
HTTPS to HTTP Insecure Transition in Form Post	Passive	MEDIUM	-
User Controllable JavaScript Event (XSS)	Passive	MEDIUM	-
Big Redirect Detected (Potential Sensitive Information Leak)	Passive	MEDIUM	-
X-ChromeLogger-Data (XCOLD) Header Information Leak	Passive	MEDIUM	-
Cookie without SameSite Attribute	Passive	MEDIUM	-
CSP	Passive	MEDIUM	-
X-Debug-Token Information Leak	Passive	MEDIUM	-
Username Hash Found	Passive	MEDIUM	-
X-AspNet-Version Response Header	Passive	MEDIUM	-
PII Disclosure	Passive	MEDIUM	-
Script Passive Scan Rules	Passive	MEDIUM	-
Stats Passive Scan Rule	Passive	MEDIUM	-

HostedScan Free Trial Report

Timestamp Disclosure	Passive	MEDIUM	-
Hash Disclosure	Passive	MEDIUM	-
Weak Authentication Method	Passive	MEDIUM	-
Reverse Tabnabbing	Passive	MEDIUM	-
Modern Web Application	Passive	MEDIUM	-
Authentication Request Identified	Passive	MEDIUM	-

Alert Detail

Medium	Absence of Anti-CSRF Tokens
Description	No Anti-CSRF tokens were found in a HTML submission form. A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL/form actions in a repeatable way. The nature of the attack is that CSRF exploits the trust that a web site has for a user. By contrast, cross-site scripting (XSS) exploits the trust that a user has for a web site. Like XSS, CSRF attacks are not necessarily cross-site, but they can be. Cross-site request forgery is also known as CSRF, XSRF, one-click attack, session riding, confused deputy, and sea surf. CSRF attacks are effective in a number of situations, including: * The victim has an active session on the target site. * The victim is authenticated via HTTP auth on the target site. * The victim is on the same local network as the target site. CSRF has primarily been used to perform an action against a target site using the victim's privileges, but recent techniques have been discovered to disclose information by gaining access to the response. The risk of information disclosure is dramatically increased when the target site is vulnerable to XSS, because XSS can be used as a platform for CSRF, allowing the attack to operate within the bounds of the same-origin policy.
URL	https://u77w41.github.io/tags/
Method	GET
Parameter	
Attack	
Evidence	<form method=dialog class=pagination-jump-form>
Other Info	No known Anti-CSRF token [anticsrf, CSRFToken, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf, csrf_token, _csrf, _csrfSecret, __csrf_magic, CSRF, _token, _csrf_token, _csrfToken, data[_Token][key], _wpnonce] was found in the following HTML form: [Form 1: "pagination-jump-input"].
Request Header	GET https://u77w41.github.io/tags/ HTTP/1.1 host: u77w41.github.io user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 pragma: no-cache cache-control: no-cache referer: https://u77w41.github.io/sitemap.xml
Request Body	
Response Header	HTTP/1.1 200 OK Connection: keep-alive Content-Length: 17563 Server: GitHub.com Content-Type: text/html; charset=utf-8 x-origin-cache: HIT Last-Modified: Tue, 27 Oct 2026 05:44:13 GMT

	Access-Control-Allow-Origin: * Strict-Transport-Security: max-age=31556952 ETag: "6ae03a2d-449b" expires: Tue, 27 Oct 2026 06:19:36 GMT Cache-Control: max-age=600 x-proxy-cache: MISS X-GitHub-Request-Id: 69C6:5A36F:D489F:EFCEA:6AE04020 x-github-edge-region: iad Accept-Ranges: bytes Age: 0 Date: Tue, 27 Oct 2026 06:09:36 GMT Via: 1.1 varnish X-Served-By: cache-iad-kcgs7200149-IAD X-Cache: MISS X-Cache-Hits: 0 X-Timer: S1793081376.497818,VS0,VE31 Vary: Accept-Encoding X-Fastly-Request-ID: 1bc1da78de5e3516aaaa0d8f2ec6c5fb43e63b3b
Response Body **(excerpt)**	nejoin="round" class="icon icon-tabler icons-tabler-outline icon-tabler-chevron-right"><path stroke="none" d="M0 0h24v24H0z" fill="none"/><path d="M9 6l6 6-6 6"/></svg></nav><dialog id=pagination-jump-dialog aria-labelledby=pagination-jump-title>**<form method=dialog class=pagination-jump-form>**<header><label id=pagination-jump-title class=title for=pagination-jump-input>Jump to page </label>(1 - 3)</header> <input type=number id=pagination-jump-input min=1 max=3 autofocus au
URL	https://u77w41.github.io/tags/page/2/
Method	GET
Parameter	
Attack	
Evidence	<form method=dialog class=pagination-jump-form>
Other Info	No known Anti-CSRF token [anticsrf, CSRFToken, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf, csrf_token, _csrf, _csrfSecret, __csrf_magic, CSRF, _token, _csrf_token, _csrfToken, data[_Token][key], _wpnonce] was found in the following HTML form: [Form 1: "pagination-jump-input"].
URL	https://u77w41.github.io/tags/page/3/
Method	GET
Parameter	
Attack	
Evidence	<form method=dialog class=pagination-jump-form>
Other Info	No known Anti-CSRF token [anticsrf, CSRFToken, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf, csrf_token, _csrf, _csrfSecret, __csrf_magic, CSRF, _token, _csrf_token, _csrfToken, data[_Token][key], _wpnonce] was found in the following HTML form: [Form 1: "pagination-jump-input"].
Instances	3
Solution	Phase: Architecture and Design Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid. For example, use anti-CSRF packages such as the OWASP CSRFGuard. Phase: Implementation Ensure that your application is free of cross-site scripting issues, because most CSRF defenses can be bypassed using attacker-controlled script. Phase: Architecture and Design Generate a unique nonce for each form, place the nonce into the form, and verify the nonce upon receipt of the form. Be sure that the nonce is not predictable (CWE-330).

	Note that this can be bypassed using XSS. Identify especially dangerous operations. When the user performs a dangerous operation, send a separate confirmation request to ensure that the user intended to perform that operation. Note that this can be bypassed using XSS. Use the ESAPI Session Management control. This control includes a component for CSRF. Do not use the GET method for any request that triggers a state change. Phase: Implementation Check the HTTP Referer header to see if the request originated from an expected page. This could break legitimate functionality, because users or proxies may have disabled sending the Referer for privacy reasons.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html https://cwe.mitre.org/data/definitions/352.html
CWE Id	352
WASC Id	9
Plugin Id	10202

Medium	**Content Security Policy (CSP) Header Not Set**
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	https://u77w41.github.io/anurup/
Method	GET
Parameter	
Attack	
Evidence	
Other Info	

Request Header	`GET https://u77w41.github.io/anurup/ HTTP/1.1`
	`host: u77w41.github.io`
	`user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36`
	`pragma: no-cache`
	`cache-control: no-cache`

Request Body	

Response Header	`HTTP/1.1 200 OK`
	`Connection: keep-alive`
	`Content-Length: 10556`
	`Server: GitHub.com`
	`Content-Type: text/html; charset=utf-8`
	`Last-Modified: Tue, 27 Oct 2026 01:58:45 GMT`
	`Access-Control-Allow-Origin: *`
	`Strict-Transport-Security: max-age=31556952`
	`ETag: "6ae00555-293c"`
	`expires: Tue, 27 Oct 2026 06:19:35 GMT`
	`Cache-Control: max-age=600`
	`x-proxy-cache: MISS`
	`X-GitHub-Request-Id: F890:33DC48:11CD00:134ECA:6AE0401F`

	x-github-edge-region: iad Accept-Ranges: bytes Age: 0 Date: Tue, 27 Oct 2026 06:09:35 GMT Via: 1.1 varnish X-Served-By: cache-iad-kiad7000204-IAD X-Cache: MISS X-Cache-Hits: 0 X-Timer: S1793081376.577069,VS0,VE25 Vary: Accept-Encoding X-Fastly-Request-ID: f150a25956ee92dd14f367553001ea14320a9c03
Response Body **(truncated)**	<!doctype html> <html lang="en"> <head> <meta charset="UTF-8" /> <meta name="viewport" content="width=device-width, initial-scale=1.0" /> <title>ANURUP | Free photo and PDF tools for online forms</title> <meta name="description" content="Resize photos to exact KB, make passport size photos, clean signatures, and merge, compress or unlock PDFs. Free, no sign-up, and files stay in your browser." /> <link rel="canonical" href="https://u77w41.github.io/anurup/" /> <meta nam...(truncated)
URL	https://u77w41.github.io/anurup/format-converter/
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	https://u77w41.github.io/anurup/image-compressor/
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	https://u77w41.github.io/anurup/passport-photo/
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	https://u77w41.github.io/anurup/size-targeter/
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
Instances	5

Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	**Cross-Domain Misconfiguration**
Description	Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.
URL	https://u77w41.github.io/anurup/
Method	GET
Parameter	
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.

Request Header	`GET https://u77w41.github.io/anurup/ HTTP/1.1`
	`host: u77w41.github.io`
	`user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36`
	`pragma: no-cache`
	`cache-control: no-cache`

Request Body	

HostedScan Free Trial Report

Response Header	HTTP/1.1 200 OK Connection: keep-alive Content-Length: 10556 Server: GitHub.com Content-Type: text/html; charset=utf-8 Last-Modified: Tue, 27 Oct 2026 01:58:45 GMT **Access-Control-Allow-Origin: *** Strict-Transport-Security: max-age=31556952 ETag: "6ae00555-293c" expires: Tue, 27 Oct 2026 06:19:35 GMT Cache-Control: max-age=600 x-proxy-cache: MISS X-GitHub-Request-Id: F890:33DC48:11CD00:134ECA:6AE0401F x-github-edge-region: iad Accept-Ranges: bytes Age: 0 Date: Tue, 27 Oct 2026 06:09:35 GMT Via: 1.1 varnish X-Served-By: cache-iad-kiad7000204-IAD X-Cache: MISS X-Cache-Hits: 0 X-Timer: S1793081376.577069,VS0,VE25 Vary: Accept-Encoding X-Fastly-Request-ID: f150a25956ee92dd14f367553001ea14320a9c03
Response Body **(truncated)**	<!doctype html> <html lang="en"> <head> <meta charset="UTF-8" /> <meta name="viewport" content="width=device-width, initial-scale=1.0" /> <title>ANURUP | Free photo and PDF tools for online forms</title> <meta name="description" content="Resize photos to exact KB, make passport size photos, clean signatures, and merge, compress or unlock PDFs. Free, no sign-up, and files stay in your browser." /> <link rel="canonical" href="https://u77w41.github.io/anurup/" /> <meta nam...(truncated)
URL	https://u77w41.github.io/anurup/passport-photo/
Method	GET
Parameter	
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	https://u77w41.github.io/anurup/size-targeter/
Method	GET
Parameter	
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	https://u77w41.github.io/robots.txt

Method	GET
Parameter	
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	https://u77w41.github.io/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
Instances	5
Solution	Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance). Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.
Reference	https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy
CWE Id	264
WASC Id	14
Plugin Id	10098

Medium	**Missing Anti-clickjacking Header**
Description	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
URL	https://u77w41.github.io/anurup/
Method	GET
Parameter	x-frame-options
Attack	
Evidence	
Other Info	

Request Header	`GET https://u77w41.github.io/anurup/ HTTP/1.1`
	`host: u77w41.github.io`
	`user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36`
	`pragma: no-cache`
	`cache-control: no-cache`

Request Body	

Response Header	`HTTP/1.1 200 OK`
	`Connection: keep-alive`
	`Content-Length: 10556`
	`Server: GitHub.com`

	Content-Type: text/html; charset=utf-8 Last-Modified: Tue, 27 Oct 2026 01:58:45 GMT Access-Control-Allow-Origin: * Strict-Transport-Security: max-age=31556952 ETag: "6ae00555-293c" expires: Tue, 27 Oct 2026 06:19:35 GMT Cache-Control: max-age=600 x-proxy-cache: MISS X-GitHub-Request-Id: F890:33DC48:11CD00:134ECA:6AE0401F x-github-edge-region: iad Accept-Ranges: bytes Age: 0 Date: Tue, 27 Oct 2026 06:09:35 GMT Via: 1.1 varnish X-Served-By: cache-iad-kiad7000204-IAD X-Cache: MISS X-Cache-Hits: 0 X-Timer: S1793081376.577069,VS0,VE25 Vary: Accept-Encoding X-Fastly-Request-ID: f150a25956ee92dd14f367553001ea14320a9c03
Response Body **(truncated)**	<!doctype html> <html lang="en"> <head> <meta charset="UTF-8" /> <meta name="viewport" content="width=device-width, initial-scale=1.0" /> <title>ANURUP | Free photo and PDF tools for online forms</title> <meta name="description" content="Resize photos to exact KB, make passport size photos, clean signatures, and merge, compress or unlock PDFs. Free, no sign-up, and files stay in your browser." /> <link rel="canonical" href="https://u77w41.github.io/anurup/" /> <meta nam...(truncated)
URL	https://u77w41.github.io/anurup/format-converter/
Method	GET
Parameter	x-frame-options
Attack	
Evidence	
Other Info	
URL	https://u77w41.github.io/anurup/image-compressor/
Method	GET
Parameter	x-frame-options
Attack	
Evidence	
Other Info	
URL	https://u77w41.github.io/anurup/passport-photo/
Method	GET
Parameter	x-frame-options
Attack	
Evidence	
Other Info	
URL	https://u77w41.github.io/anurup/size-targeter/
Method	GET

Parameter	x-frame-options
Attack	
Evidence	
Other Info	
Instances	5
Solution	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
CWE Id	1021
WASC Id	15
Plugin Id	10020

Medium	**Sub Resource Integrity Attribute Missing**
Description	The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content.
URL	https://u77w41.github.io/p/anurup/
Method	GET
Parameter	
Attack	
Evidence	<link rel=preload as=style href="https://fonts.googleapis.com/css2?family=Lato:wght@300;400;700&display=swap">
Other Info	
Request Header	GET https://u77w41.github.io/p/anurup/ HTTP/1.1 host: u77w41.github.io user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 pragma: no-cache cache-control: no-cache referer: https://u77w41.github.io/sitemap.xml
Request Body	
Response Header	HTTP/1.1 200 OK Connection: keep-alive Content-Length: 28904 Server: GitHub.com Content-Type: text/html; charset=utf-8 x-origin-cache: HIT Last-Modified: Tue, 27 Oct 2026 05:44:13 GMT Access-Control-Allow-Origin: * Strict-Transport-Security: max-age=31556952 ETag: "6ae03a2d-70e8" expires: Tue, 27 Oct 2026 06:19:36 GMT Cache-Control: max-age=600 x-proxy-cache: MISS X-GitHub-Request-Id: 7AD6:2D6D1F:10A1BB:1224C2:6AE04020 x-github-edge-region: iad Accept-Ranges: bytes Age: 0 Date: Tue, 27 Oct 2026 06:09:36 GMT Via: 1.1 varnish

	X-Served-By: cache-iad-khef600087-IAD X-Cache: MISS X-Cache-Hits: 0 X-Timer: S1793081376.190648,VS0,VE28 Vary: Accept-Encoding X-Fastly-Request-ID: c39b9bf3a367a6f62bb2c1c8692d5f792db85b7a
Response Body **(excerpt)**	ver uploaded."><title>ANURUP: privacy-first photo and PDF tools</title><link rel=canonical href=https://u77w41.github.io/p/anurup/><link rel=preconnect href=https://fonts.googleapis.com><link rel=preconnect href=https://fonts.gstatic.com crossorigin><**link rel=preload as=style href="https://fonts.googleapis.com/css2?family=Lato:wght@300;400;700&display=swap"**><link rel=stylesheet href="https://fonts.googleapis.com/css2?family=Lato:wght@300;400;700&display=swap"><link rel=stylesheet href=/scss/style.min.136ee97687da12f7030522628c92dc9e2f8adb7e85524218c785229047c12c4c.css><meta property='og:title' content="
URL	https://u77w41.github.io/p/anurup/
Method	GET
Parameter	
Attack	
Evidence	<link rel=stylesheet href="https://fonts.googleapis.com/css2?family=Lato:wght@300;400;700&display=swap">
Other Info	
URL	https://u77w41.github.io/p/forecasting-and-anomaly-detection/
Method	GET
Parameter	
Attack	
Evidence	<link rel=preload as=style href="https://fonts.googleapis.com/css2?family=Lato:wght@300;400;700&display=swap">
Other Info	
URL	https://u77w41.github.io/p/forecasting-and-anomaly-detection/
Method	GET
Parameter	
Attack	
Evidence	<link rel=stylesheet href="https://fonts.googleapis.com/css2?family=Lato:wght@300;400;700&display=swap">
Other Info	
URL	https://u77w41.github.io/p/paris-summer-olympic-games-2024-dashboard/
Method	GET
Parameter	
Attack	
Evidence	<link rel=preload as=style href="https://fonts.googleapis.com/css2?family=Lato:wght@300;400;700&display=swap">
Other Info	
Instances	5
Solution	Provide a valid integrity attribute to the tag.
Reference	https://developer.mozilla.org/en-US/docs/Web/Security/Defenses/Subresource_Integrity
CWE Id	345
WASC Id	15
Plugin Id	90003
Low	**Strict-Transport-Security Header Not Set**

Description	HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797.
URL	https://u77w41.github.io/anurup/sw.js
Method	GET
Parameter	
Attack	
Evidence	
Other Info	

Request Header	`GET https://u77w41.github.io/anurup/sw.js HTTP/1.1`
	`Host: u77w41.github.io`
	`User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:153.0) Gecko/20100101 Firefox/153.0`
	`Accept: */*`
	`Accept-Language: en-US,en;q=0.9`
	`Service-Worker: script`
	`Connection: keep-alive`
	`Sec-Fetch-Dest: serviceworker`
	`Sec-Fetch-Mode: same-origin`
	`Sec-Fetch-Site: same-origin`
	`If-Modified-Since: Tue, 27 Oct 2026 01:58:45 GMT`
	`If-None-Match: "6ae00555-167b"`
	`Priority: u=4`
	`Cache-Control: max-age=0`

Request Body	

Response Header	`HTTP/1.1 304 Not Modified`
	`Connection: keep-alive`
	`Date: Tue, 27 Oct 2026 06:11:30 GMT`
	`Via: 1.1 varnish`
	`Cache-Control: max-age=600`
	`ETag: "6ae00555-167b"`
	`Expires: Tue, 27 Oct 2026 06:19:45 GMT`
	`Age: 105`
	`X-Served-By: cache-iad-kiad7000075-IAD`
	`X-Cache: HIT`
	`X-Cache-Hits: 2`
	`X-Timer: S1793081491.780118,VS0,VE1`
	`Vary: Accept-Encoding`
	`X-Fastly-Request-ID: 1e90e953061d7cf7b1155c16acf627eff4d95fed`

Response Body	
Instances	1
Solution	Ensure that your web server, application server, load balancer, etc. is configured to enforce Strict-Transport-Security.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html https://owasp.org/www-community/Security_Headers https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security https://caniuse.com/stricttransportsecurity https://datatracker.ietf.org/doc/html/rfc6797
CWE Id	319
WASC Id	15
Plugin Id	10035

Low	**X-Content-Type-Options Header Missing**

Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	https://u77w41.github.io/anurup/
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.

Request Header	`GET https://u77w41.github.io/anurup/ HTTP/1.1`
	`host: u77w41.github.io`
	`user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36`
	`pragma: no-cache`
	`cache-control: no-cache`

Request Body	

Response Header	`HTTP/1.1 200 OK`
	`Connection: keep-alive`
	`Content-Length: 10556`
	`Server: GitHub.com`
	`Content-Type: text/html; charset=utf-8`
	`Last-Modified: Tue, 27 Oct 2026 01:58:45 GMT`
	`Access-Control-Allow-Origin: *`
	`Strict-Transport-Security: max-age=31556952`
	`ETag: "6ae00555-293c"`
	`expires: Tue, 27 Oct 2026 06:19:35 GMT`
	`Cache-Control: max-age=600`
	`x-proxy-cache: MISS`
	`X-GitHub-Request-Id: F890:33DC48:11CD00:134ECA:6AE0401F`
	`x-github-edge-region: iad`
	`Accept-Ranges: bytes`
	`Age: 0`
	`Date: Tue, 27 Oct 2026 06:09:35 GMT`
	`Via: 1.1 varnish`
	`X-Served-By: cache-iad-kiad7000204-IAD`
	`X-Cache: MISS`
	`X-Cache-Hits: 0`
	`X-Timer: S1793081376.577069,VS0,VE25`
	`Vary: Accept-Encoding`
	`X-Fastly-Request-ID: f150a25956ee92dd14f367553001ea14320a9c03`

Response Body **(truncated)**	`<!doctype html>`
	`<html lang="en">`
	`  <head>`
	`    <meta charset="UTF-8" />`
	`    <meta name="viewport" content="width=device-width, initial-scale=1.0" />`
	`    <title>ANURUP | Free photo and PDF tools for online forms</title>`
	`    <meta name="description" content="Resize photos to exact KB, make passport size photos, clean signatures, and merge, compress or unlock PDFs. Free, no sign-up, and files stay in your browser." />`
	`    <link rel="canonical" href="https://u77w41.github.io/anurup/" />`
	`    <meta nam...(truncated)`

URL	https://u77w41.github.io/anurup/passport-photo/
Method	GET

HostedScan Free Trial Report

Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://u77w41.github.io/anurup/size-targeter/
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://u77w41.github.io/robots.txt
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://u77w41.github.io/sitemap.xml
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	5
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security_Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	**Information Disclosure - Information in Browser localStorage**
Description	Information was stored in browser localStorage. This is not unusual or necessarily unsafe - this informational alert has been raised to help you get a better understanding of what this app is doing. For more details see the Client tabs - this information was set directly in the browser and will therefore not necessarily appear in this form in any HTTP(S) messages.
URL	https://u77w41.github.io/
Method	GET
Parameter	StackColorScheme

Attack	
Evidence	
Other Info	The following data (key=value) was set: StackColorScheme=auto Note that this alert will only be raised once for each URL + key.
Request Header	GET https://u77w41.github.io/ HTTP/1.1 Host: u77w41.github.io User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:153.0) Gecko/20100101 Firefox/153.0 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 Accept-Language: en-US,en;q=0.9 Connection: keep-alive Referer: https://u77w41.github.io/support-my-work/ Upgrade-Insecure-Requests: 1 Sec-Fetch-Dest: document Sec-Fetch-Mode: navigate Sec-Fetch-Site: same-origin Sec-Fetch-User: ?1 Priority: u=0, i
Request Body	
Response Header	HTTP/1.1 200 OK Connection: keep-alive Content-Length: 26922 Server: GitHub.com Content-Type: text/html; charset=utf-8 x-origin-cache: HIT Last-Modified: Tue, 27 Oct 2026 05:44:13 GMT Access-Control-Allow-Origin: * Strict-Transport-Security: max-age=31556952 ETag: "6ae03a2d-692a" expires: Tue, 27 Oct 2026 06:19:36 GMT Cache-Control: max-age=600 x-proxy-cache: MISS X-GitHub-Request-Id: 6586:1E0307:118213:1305C7:6AE04020 x-github-edge-region: iad Accept-Ranges: bytes Date: Tue, 27 Oct 2026 06:10:00 GMT Via: 1.1 varnish Age: 24 X-Served-By: cache-iad-khef600087-IAD X-Cache: HIT X-Cache-Hits: 1 X-Timer: S1793081400.018694,VS0,VE1 Vary: Accept-Encoding X-Fastly-Request-ID: 73644f0aad66acfa76279cfaaff41da43a35580f
Response Body **(truncated)**	<!doctype html><html lang=en-us dir=ltr><head><meta charset=utf-8><meta name=viewport content='width=device-width,initial-scale=1'><meta name=description content="Data Scientist, Fraud & Risk Analytics @ RBIH"><title>Ujjwal Chowdhury</title><link rel=canonical href=https://u77w41.github.io/><link rel=preconnect href=https://fonts.googleapis.com><link rel=preconnect href=https://fonts.gstatic.com crossorigin><link rel=preload as=style href="https://fonts.googleapis.com/css2?family=Lato:wght@300;4...(truncated)
URL	https://u77w41.github.io/resume/
Method	GET
Parameter	StackColorScheme
Attack	
Evidence	
Other Info	The following data (key=value) was set: StackColorScheme=auto Note that this alert will only be raised once for each URL + key.

URL	https://u77w41.github.io/support-my-work/
Method	GET
Parameter	StackColorScheme
Attack	
Evidence	
Other Info	The following data (key=value) was set: StackColorScheme=dark Note that this alert will only be raised once for each URL + key.
Instances	3
Solution	This is an informational alert and no action is necessary.
Reference	
CWE Id	359
WASC Id	13
Plugin Id	120000

Informational	**Re-examine Cache-control Directives**
Description	The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended, however, the resources should be reviewed to ensure that no sensitive content will be cached.
URL	https://u77w41.github.io/anurup/
Method	GET
Parameter	cache-control
Attack	
Evidence	max-age=600
Other Info	

Request Header

```
GET https://u77w41.github.io/anurup/ HTTP/1.1
host: u77w41.github.io
user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/5
37.36
pragma: no-cache
cache-control: no-cache
```

Request Body

Response Header

```
HTTP/1.1 200 OK
Connection: keep-alive
Content-Length: 10556
Server: GitHub.com
Content-Type: text/html; charset=utf-8
Last-Modified: Tue, 27 Oct 2026 01:58:45 GMT
Access-Control-Allow-Origin: *
Strict-Transport-Security: max-age=31556952
ETag: "6ae00555-293c"
expires: Tue, 27 Oct 2026 06:19:35 GMT
Cache-Control: max-age=600
x-proxy-cache: MISS
X-GitHub-Request-Id: F890:33DC48:11CD00:134ECA:6AE0401F
x-github-edge-region: iad
Accept-Ranges: bytes
Age: 0
Date: Tue, 27 Oct 2026 06:09:35 GMT
Via: 1.1 varnish
X-Served-By: cache-iad-kiad7000204-IAD
X-Cache: MISS
X-Cache-Hits: 0
```

	X-Timer: S1793081376.577069,VS0,VE25 Vary: Accept-Encoding X-Fastly-Request-ID: f150a25956ee92dd14f367553001ea14320a9c03
Response Body **(truncated)**	<!doctype html> <html lang="en"> <head> <meta charset="UTF-8" /> <meta name="viewport" content="width=device-width, initial-scale=1.0" /> <title>ANURUP | Free photo and PDF tools for online forms</title> <meta name="description" content="Resize photos to exact KB, make passport size photos, clean signatures, and merge, compress or unlock PDFs. Free, no sign-up, and files stay in your browser." /> <link rel="canonical" href="https://u77w41.github.io/anurup/" /> <meta nam...(truncated)
URL	https://u77w41.github.io/anurup/passport-photo/
Method	GET
Parameter	cache-control
Attack	
Evidence	max-age=600
Other Info	
URL	https://u77w41.github.io/anurup/size-targeter/
Method	GET
Parameter	cache-control
Attack	
Evidence	max-age=600
Other Info	
URL	https://u77w41.github.io/robots.txt
Method	GET
Parameter	cache-control
Attack	
Evidence	max-age=600
Other Info	
URL	https://u77w41.github.io/sitemap.xml
Method	GET
Parameter	cache-control
Attack	
Evidence	max-age=600
Other Info	
Instances	5
Solution	For secure content, ensure the cache-control HTTP header is set with "no-cache, no-store, must-revalidate". If an asset should be cached consider setting the directives "public, max-age, immutable".
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control https://grayduck.mn/2021/09/13/cache-control-recommendations/
CWE Id	525
WASC Id	13

Plugin Id	10015

Informational	Retrieved from Cache
Description	The content was retrieved from a shared cache. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.
URL	https://u77w41.github.io/anurup/
Method	GET
Parameter	
Attack	
Evidence	HIT
Other Info	
Request Header	GET https://u77w41.github.io/anurup/ HTTP/1.1 host: u77w41.github.io user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36 pragma: no-cache cache-control: no-cache
Request Body	
Response Header	HTTP/1.1 200 OK Connection: keep-alive Content-Length: 10556 Server: GitHub.com Content-Type: text/html; charset=utf-8 Last-Modified: Tue, 27 Oct 2026 01:58:45 GMT Access-Control-Allow-Origin: * Strict-Transport-Security: max-age=31556952 ETag: "6ae00555-293c" expires: Tue, 27 Oct 2026 06:19:35 GMT Cache-Control: max-age=600 x-proxy-cache: MISS X-GitHub-Request-Id: F890:33DC48:11CD00:134ECA:6AE0401F x-github-edge-region: iad Accept-Ranges: bytes Date: Tue, 27 Oct 2026 06:09:35 GMT Via: 1.1 varnish Age: 0 X-Served-By: cache-iad-khef600074-IAD X-Cache: **HIT** X-Cache-Hits: 1 X-Timer: S1793081376.811768,VS0,VE2 Vary: Accept-Encoding X-Fastly-Request-ID: 1d17b2116279b32b4b9da4d194023e2f3c1b8af9

Response Body **(truncated)**	<!doctype html> <html lang="en"> <head> <meta charset="UTF-8" /> <meta name="viewport" content="width=device-width, initial-scale=1.0" /> <title>ANURUP | Free photo and PDF tools for online forms</title> <meta name="description" content="Resize photos to exact KB, make passport size photos, clean signatures, and merge, compress or unlock PDFs. Free, no sign-up, and files stay in your browser." /> <link rel="canonical" href="https://u77w41.github.io/anurup/" /> <meta nam...(truncated)
URL	https://u77w41.github.io/anurup/?c=photo
Method	GET
Parameter	
Attack	
Evidence	HIT
Other Info	
URL	https://u77w41.github.io/anurup/
Method	GET
Parameter	
Attack	
Evidence	Age: 0
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
URL	https://u77w41.github.io/anurup/passport-photo/
Method	GET
Parameter	
Attack	
Evidence	Age: 0
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
URL	https://u77w41.github.io/anurup/size-targeter/
Method	GET
Parameter	
Attack	
Evidence	Age: 0
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
URL	https://u77w41.github.io/robots.txt
Method	GET
Parameter	
Attack	
Evidence	Age: 0
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
URL	https://u77w41.github.io/sitemap.xml
Method	GET
Parameter	

Attack	
Evidence	Age: 0
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
Instances	7
Solution	Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user: Cache-Control: no-cache, no-store, must-revalidate, private Pragma: no-cache Expires: 0 This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.
Reference	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.rfc-editor.org/rfc/rfc9110.html
CWE Id	525
WASC Id	
Plugin Id	10050

HostedScan Free Trial Report